Security & Threat Model

CABINGUARD-ADI: A Zero-Compliance Multimodal In-Cabin Framework for Prodromal Prediction and Fail-Safe Actuation in Acute Driver Incapacitation

TSYP14 Technical Challenge — ISO/SAE 21434-Informed Security, SecOC CAN-FD and Privacy-Preserving V2X

---

1. Security Objective

The security architecture protects the path from multimodal medical-event reasoning to safety-critical vehicle actuation while preserving biometric privacy. It must prevent corrupted, replayed, missing, contradictory, or unauthorized information from causing unsafe actuation.

2. Protected Assets

Asset	Security Relevance
Raw optical, BCG, respiratory and pressure data	Sensitive in-cabin biometric and behavioral information.
Fusion confidence and uncertainty	Directly influence safety-state transitions.
Conflict and source-availability indicators	Determine whether the system acts or abstains.
CAN-FD command `0x1B4`	Carries the safety-critical MRM request and `LockEPS`.
Freshness information and SecOC authentication data	Protect against replay and modification.
DENM emergency payload	External minimum-necessary emergency information.
Dataset provenance metadata	Distinguishes real baseline observations from synthetic feature-level transformations and preserves traceability during evaluation.

3. Trust Boundaries

1. **Sensor boundary:** cabin sensors may become degraded, missing, inconsistent, or spoofed.
2. **EPU boundary:** preprocessing, calibration, fusion, uncertainty, and decision logic execute locally.
3. **Vehicle-network boundary:** safety commands cross from the EPU to native vehicle controllers through CAN-FD.
4. **External V2X boundary:** only minimum-necessary anonymized emergency information leaves the vehicle.

4. STRIDE-Oriented Threat Analysis

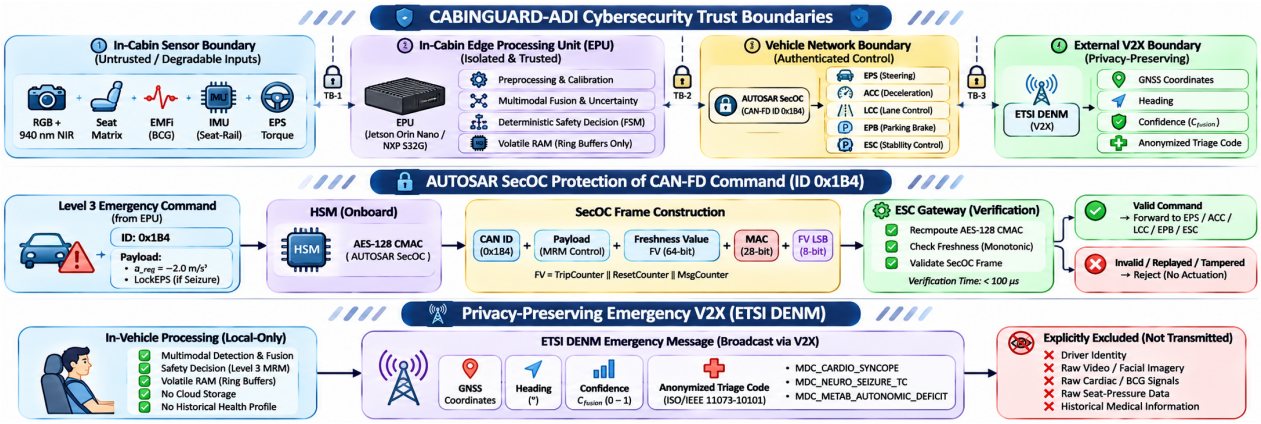


Figure 1: Original CABINGUARD-ADI cybersecurity infographic retained unchanged. Any verification-time value visible inside the legacy artwork is not claimed as a measured result in the corrected submission.

Category	Threat	Potential Impact	Proposed Control
Spoofing	Optical blinding or falsified sensor evidence	False or suppressed medical-event inference	Cross-modal plausibility, quality checks, conflict abstention
Tampering	Modified safety-command payload	Unsafe braking or steering command	AUTOSAR SecOC CMAC verification
Repudiation	Unverifiable command origin	Untrusted safety command	SecOC-authenticated command generation
Information Disclosure	Exposure of raw biometric data	Privacy loss	Local processing, volatile RAM, minimal V2X
Denial of Service	Missing / degraded sensor or communication source	Incomplete evidence	Source-availability monitoring and fail-silent behavior
Elevation of Privilege	Unauthorized CAN command injection	Unauthorized vehicle actuation	Authentication and freshness verification
Data Provenance Error	Synthetic sample represented as real clinical evidence	Invalid evaluation claim or leakage	Provenance metadata and source-linked partitioning

5. Tampered, Replayed and Missing Data

The system explicitly handles:

- missing modalities;
- modified sensor or communication values;
- replayed CAN messages;
- optical spoofing / blinding;
- physically contradictory multimodal evidence.

Fail-silent behavior is triggered when evidence is not sufficiently trustworthy, including conflict or insufficient source availability. No braking command is issued from an unresolved contradictory state.

6. Secure CAN-FD Vehicle Interface

Level 3 safety commands use:

$$\texttt{ID} = \texttt{0x1B4}.$$

The proposed payload contains the MRM request, including:

$$a_{\text{req}} = -2.0 \text{ m/s}^2$$

and seizure-dependent `LockEPS`.

AUTOSAR SecOC protects the command using an HSM-generated AES-128 CMAC over the CAN identifier, command payload, and monotonic freshness information:

$$\text{FV} = \text{TripCounter} \parallel \text{ResetCounter} \parallel \text{MsgCounter}.$$

The design appends a truncated 28-bit MAC and an 8-bit freshness-value LSB. Replay/tamper rejection rate and gateway verification latency are **test metrics**, not claimed performance values.

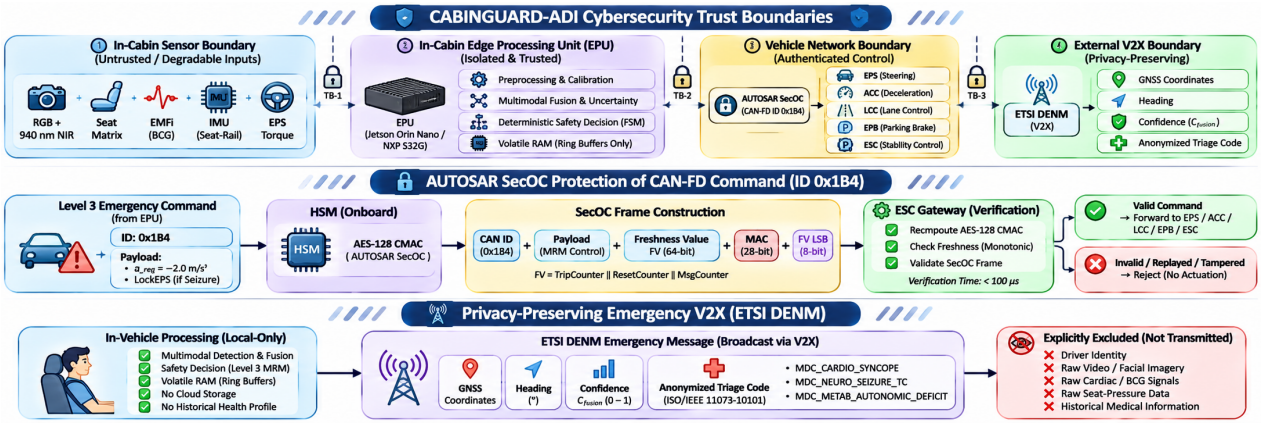


Figure 2: Original AUTOSAR SecOC / CAN-FD security infographic retained unchanged. Numerical verification-time text inside the legacy artwork is illustrative, not an experimentally established result.

7. Unauthorized Command Protection

The intended control path is:

$$\text{EPU} \rightarrow \text{HSM / SecOC} \rightarrow \text{CAN-FD} \rightarrow \text{Vehicle Gateway} \rightarrow \text{Native Controllers}.$$

A command that fails authentication or freshness verification is not forwarded for actuation.

7.1 Dataset Provenance and Synthetic-Scenario Integrity

Training and evaluation data must preserve the distinction between real observations and synthetic scenario transformations. For every derived sample, the evaluation record retains:

$$\mathcal{R} = \{\text{source dataset}, \text{source sample}, \text{real/synthetic flag}, \text{scenario}, \text{phase}, \text{injected features}\}.$$

This metadata is part of the evaluation trust boundary: a synthetic scenario must never be represented as an observed clinical event. Synthetic derivatives originating from one baseline subject/session must remain in the same train/validation/test partition as their source to prevent data leakage.

8. Privacy Model

Raw in-vehicle optical and physiological data are processed locally using volatile RAM ring buffers. Public dataset samples used during offline Phase 1 evaluation remain separate from the runtime vehicle-data path. The architecture does not require persistent raw video, persistent biometric streams, historical health profiles, or cloud biometric storage.

9. Privacy-Preserving V2X

The proposed ETSI DENM emergency packet contains only:

- GNSS position;
- vehicle heading;
- fusion confidence;
- anonymized triage information.

It excludes driver identity, raw facial imagery, raw cardiac waveforms, raw seat-pressure data, and historical medical information.

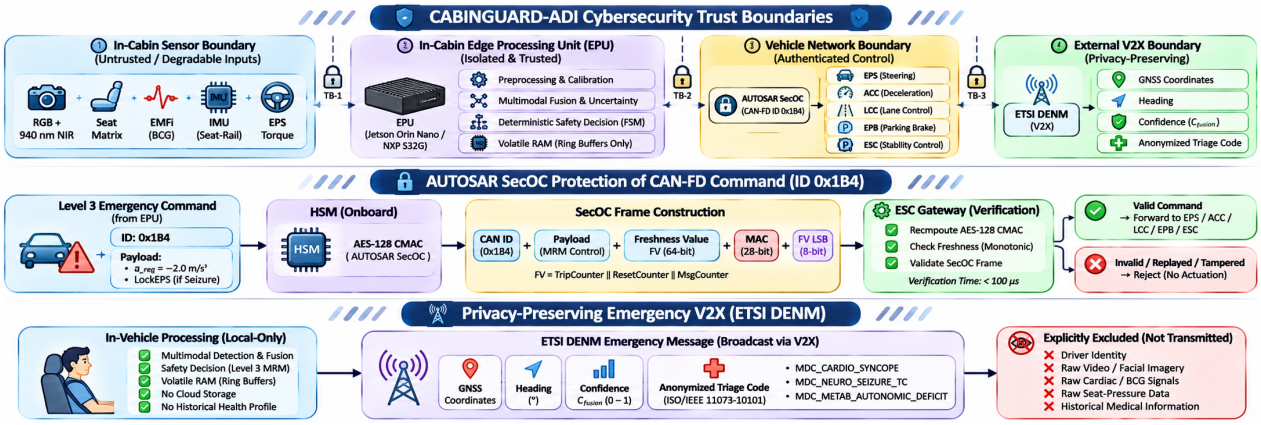


Figure 3: Original privacy-preserving ETSI DENM infographic retained unchanged.

10. Security Validation Plan

The planned software security test will inject:

- valid frames;
- replayed frames;
- modified frames;
- missing sensor sources;
- contradictory multimodal states.

The evaluation will measure replay/tamper rejection, unauthorized-command rejection, and fail-silent behavior. No numerical cybersecurity success rate is claimed before testing.

11. Validation Status

Full security and fault benchmarking is pending access to the compute resources required for repeated multimodal and communication-fault campaigns. Subsequent Phase 2 validation must reproduce the tests on an approved embedded, CAN, robotic, or vehicle-simulation environment.